



Month 1 Security Assessment Report

Consolidated Assessment - INC-2026-001 to INC-2026-003

PREPARED FOR

NexaCorp Industries

Board briefing, end of Month 1

Month 1 Linux infrastructure security assessment

Reference BCC-2026 | INC-2026-001 to 003

Prepared by

Johan-Emmanuel Hatchi, SOC Analyst L1

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi · github.com/Jhatchi

Date: 28 May 2026

Table of Contents

CONFIDENTIALITY STATEMENT	3
EXECUTIVE SUMMARY	4
FINDINGS OF THE MONTH	6
Finding 01 - Linux infrastructure compromise	6
Finding 02 - Privilege escalation and persistence	6
Finding 03 - Lateral movement and persistence	6
ATTACK CHAIN NARRATIVE	8
RISK MATRIX	9
RECOMMENDATIONS	10
APPENDIX (TECHNICAL)	11

Confidentiality Statement

This Month 1 Security Assessment Report consolidates three incident investigations (INC-2026-001 to INC-2026-003) conducted for the fictitious client NexaCorp within the BeCode Corp internal cybersecurity training programme. It is intended for NexaCorp management and the board. No real production system, customer data, or third party was involved.

The report is classified Confidential, do not distribute outside BeCode Corp, under reference BCC-2026 | INC-2026-001 to 003. Raw evidence (logs, network captures) is retained by BeCode Corp and is not redistributed. Per-incident technical detail is in the individual reports INC-2026-001 through INC-2026-003.

Executive Summary

Over the first month of monitoring, NexaCorp's Linux server estate was the target of **three connected security incidents (INC-2026-001 to INC-2026-003)**. They are not three separate events : they are one adversary, operating through the Tor anonymity network, progressively moving from one internal server to the next by reusing stolen access rather than breaking in again each time.

Key numbers for the month:

- **3 internal Linux servers compromised** to root level (Liege services, Brussels application, Liege file server).
- **2 backdoor accounts** created (it_support, sysupdate).
- **2 persistence mechanisms** installed (cron-based callbacks).
- **1 pre-existing implant** (a MITRE Caldera C2 agent) found already running on the first server, predating the monitoring window.
- **SSH keys reused across service accounts**, which let the attacker pivot host-to-host with no new exploit.

Is a GDPR notification required? Not on the basis of these incidents.

Month 1 was an infrastructure compromise (server access, SSH keys, password hashes). No exfiltration of identifiable employee personal data was confirmed in this period. Credential exposure is nonetheless serious and feeds later incidents. This contrasts with the Month 2 assessment, where a confirmed personal-data exfiltration does trigger a GDPR obligation.

The single most important point

The attacker rarely needed to exploit their way forward. They moved through the estate because **internal trust was too flat** : the same SSH key opened more than one account, a legacy service carried a 15-year-old backdoor, and there was no egress control to stop a compromised server from calling out. Each server was treated as trusted by the next. Closing the individual holes is necessary but not sufficient ; the trust model itself must be tightened.

Recommended immediate actions:

- Rotate every SSH key and stop reusing one key across multiple accounts or hosts.
- Remove the two backdoor accounts and the persistence cron jobs, and quarantine the first server (separate pre-existing implant).
- Decommission the legacy vulnerable service on the first server.
- Add egress filtering and network segmentation so a compromised host cannot freely reach others or the internet.

Findings of the Month

Finding 01 - Linux infrastructure compromise (INC-2026-001)

Risk rating:

CRITICAL

Technique:

exploitation of a 15-year-old backdoor in an outdated file-transfer service (vsftpd 2.3.4, CVE-2011-2523)

Component:

Liege services server (192.168.10.10), legacy Linux build

Impact:

unauthenticated root access (about 20 seconds, reconnaissance); the same server was also already running a hidden MITRE Caldera C2 implant beaconing externally, predating the evidence

Business impact. Full administrator exposure of a server, plus evidence of an earlier, unexplained compromise still active on it.

Finding 02 - Privilege escalation and persistence (INC-2026-002)

Risk rating:

CRITICAL

Technique:

initial access with a stolen SSH key over Tor, then root via a misconfigured SUID binary (/usr/bin/find)

Exploitation path:

login to bru-app-01 as service account svc_api, escalation to root, password-hash dump, systematic SSH key harvest

Persistence established:

backdoor account it_support and a cron callback; this foothold enables the third incident

Business impact. Durable root control of the application server and theft of the keys that unlock the rest of the estate.

Finding 03 - Lateral movement and persistence (INC-2026-003)

Risk rating:

HIGH

Technique:

lateral movement using a reused service-account SSH key, with no new exploit

Exploitation path:

from bru-app-01, the reused key authenticates to lge-files-01 as svc_backup; the system cannot distinguish the intruder from a legitimate service

Persistence established:

backdoor account sysupdate and a cron job beaconing to an external server every five minutes

Business impact. A third server under attacker control with self-restoring persistence, reached purely by abusing internal trust.

Attack Chain Narrative : one adversary, three servers

The three incidents are a single, connected progression by the same actor, anonymised through Tor:

- **INC-2026-001 (Liege services server).** The attacker exploits a legacy backdoored service to get root, and the server is found to already host a separate, pre-existing command-and-control implant.
- **INC-2026-002 (Brussels application server).** Using a stolen SSH key over Tor, the attacker logs in as a service account, escalates to root through a misconfigured binary, dumps credentials, and **harvests SSH keys**. They plant a backdoor account and persistence.
- **INC-2026-003 (Liege file server).** With one of the harvested keys, the attacker simply **logs in** to a third server as a trusted service account, no exploit needed, takes root, and installs another backdoor and a cron callback.

The connecting thread is reused trust : stolen SSH keys and a backdoor account. The attacker exploited a flaw only once (the legacy service) ; every subsequent move relied on credentials and keys that NexaCorp's own systems trusted. A compromise of one host became a compromise of the next because the trust between them was not constrained.

Risk Matrix

Each finding plotted by business Impact against Likelihood of recurrence. Upper-right is the most urgent.

Impact / Likelihood	Very Low (1)	Low (2)	Medium (3)	High (4)	Very High (5)
Very High (5)				F01, F02	
High (4)				F03	
Medium (3)					
Low (2)					
Very Low (1)					

Critical	High	Medium	Low
----------	------	--------	-----

F01 and F02 are Critical (root compromise, a pre-existing C2 implant, credential and key theft). **F03 is High** : it is a serious lateral movement with persistence, but it relied on reused trust rather than a new exploit and disclosed no additional data. All three are part of the same chain.

Recommendations

Immediate (this week)

- **Rotate all SSH keys and end key reuse.** No single key should authorise more than one account or host. This is the root cause of the lateral movement in Finding 03.
- **Remove the backdoor accounts (it_support, sysupdate) and the persistence cron jobs,** and audit all three hosts for any other unauthorized account or scheduled task.
- **Quarantine the Liege services server** : it carries a separate, pre-existing C2 implant. Acquire disk and memory images before cleanup.

Short term (this month)

- **Decommission the legacy vulnerable service** (vsftpd 2.3.4) and inventory the estate for other end-of-life software (Finding 01).
- **Fix privilege-escalation exposure** : remove the SUID bit from /usr/bin/find and audit for other SUID misconfigurations (Finding 02).
- **Implement egress filtering** so a compromised host cannot beacon out, which would have surfaced both the Caldera implant and the cron callbacks.

Strategic (this quarter)

- **Segment the network and constrain host-to-host trust** so that compromise of one server does not grant access to others.
- **Add behaviour-based detection** for first-time-sudo, new account creation, new cron entries, and service-account logins from unexpected sources.
- **Change the incident-closure process** : an incident is not closed until the attacker's established access (accounts, keys, cron jobs, implants) is removed and verified, not only the exploited flaw patched.

Appendix (technical)

Indicators of compromise (campaign)

- Attacker source 172.16.50.10 (INC-2026-001) and Tor exit nodes in 185.220.101.0/24 and related blocks (INC-2026-002, 003).
- Pre-existing Caldera C2 endpoint 10.40.0.200:8888 (INC-2026-001).
- External C2 endpoint 34.251.89.142 (INC-2026-003 cron beacon, /update?h=lge-files-01).
- Backdoor accounts : it_support (bru-app-01), sysupdate (lge-files-01).
- Persistence : cron callbacks on bru-app-01 and /etc/cron.d/system-update on lge-files-01.
- Reused service-account SSH key (svc_api key accepted for svc_backup on lge-files-01).
- Privilege escalation : SUID /usr/bin/find (mode 0104755) on bru-app-01.

Source material

Per-incident technical detail, exact timestamps, payloads and evidence references are in the individual reports INC-2026-001, INC-2026-002 and INC-2026-003. Raw evidence is retained by BeCode Corp and is not redistributed.

BeCode Corp.

DFIR / SOC Training

Reference: BCC-2026 | Month 1 Assessment (INC-2026-001 to 003)

Classification: Confidential, do not distribute outside BeCode Corp

Analyst

Johan-Emmanuel Hatchi, SOC Analyst L1

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi

github.com/Jhatchi